

Notes sur le fonctionnement du TP de cryptographie

1. Introduction

Ce TP porte sur l'utilisation de **mbedTLS**, une bibliothèque C développée par ARM. L'objectif est de sécuriser une communication entre deux appareils en utilisant le protocole TLS (Transport Layer Security), qui assure la confidentialité, l'intégrité et l'authentification.

2. Rappel : RSA

$N = p \cdot q$ (p et q premiers)
 $e \cdot d \equiv 1 \pmod{\phi(N)}$

→ Public parameters: $p_k = (N, e)$

→ Secret parameters: $s_k = d$

→ $\text{RSA-Encrypt}(p_k, m) = m^e[N] = c$

→ $\text{RSA-Decrypt}(s_k, c) = c^d[N] = m^{ed}[N] = m[N]$

$\text{Enc}(m, e, N) = m^e[N] = c$

$\text{Dec}(c, d, N) = c^d[N] = m[N] = m^{ed}[N]$

3. Mise en place dans le code

La mise en œuvre repose sur une infrastructure à clés publiques (PKI).

L'Autorité de Certification (CA)

L'Autorité de Certification signe les certificats des autres appareils pour garantir leur identité.

On génère d'abord une paire de clés RSA (publique/privée). Ensuite, on crée un certificat **auto-signé** (fichier *ca.crt*). Ce certificat contient la clé publique de la CA et doit être possédé par tous les appareils du réseau pour vérifier les futures signatures.

Le Certificat et la CSR (Certificate Signing Request)

Pour qu'un appareil soit reconnu, il ne crée pas son certificat seul, il le demande à la CA.

1. **Génération de la CSR** : L'appareil génère sa propre paire de clés et crée un fichier *.csr* contenant sa clé publique et son identité.

La fonction `mbedtls_x509write_crt_set_subject_key` est utilisée pour insérer la clé publique de l'appareil (le sujet).

`mbedtls_x509write_cert_set_issuer_key` est utilisée pour définir la clé de l'autorité qui délivre le certificat (l'émetteur).

2. **Signature** : La CA reçoit ce fichier `.csr`, le vérifie, et utilise sa propre clé privée pour signer les données de l'appareil.ivre le certificat (l'émetteur).
3. **Résultat** : L'appareil obtient un certificat (`device.crt`) qui prouve que "La CA certifie que cette clé publique appartient à cet appareil".

Un certificat contient :

- **La clé publique du détenteur**
- **L'identité du sujet** : Les informations sur le propriétaire du certificat (nom, organisation, etc.).
- **L'identité de l'émetteur** : Le nom de l'Autorité de Certification (CA) qui a signé le certificat.
- **La signature numérique** : Une empreinte du certificat chiffrée avec la clé privée de l'Autorité de Certification, garantissant que le document n'a pas été modifié.
- **La période de validité** : Les dates de début et de fin de validité du certificat.

4. Man-In-The-Middle (MITM)

La dernière partie du TP simule une attaque de l'homme du milieu.

Principe technique : L'attaquant s'interpose entre l'appareil A et l'appareil B. Dans le TP, cela est simulé par des pipes (canaux de communication) nommés `unsecured-channel-a` et `b`.

Fonctionnement de l'attaque :

1. L'appareil A pense envoyer un message à B, mais il l'envoie à l'attaquant.
2. L'attaquant intercepte, lit et peut **modifier** le message avant de le renvoyer à B.

L'utilisation de certificats validés par la CA permet à l'appareil B de vérifier que le message provient bien de l'identité de A et n'a pas été altéré, car l'attaquant ne possède pas la clé privée de la CA pour signer ses messages falsifiés.